

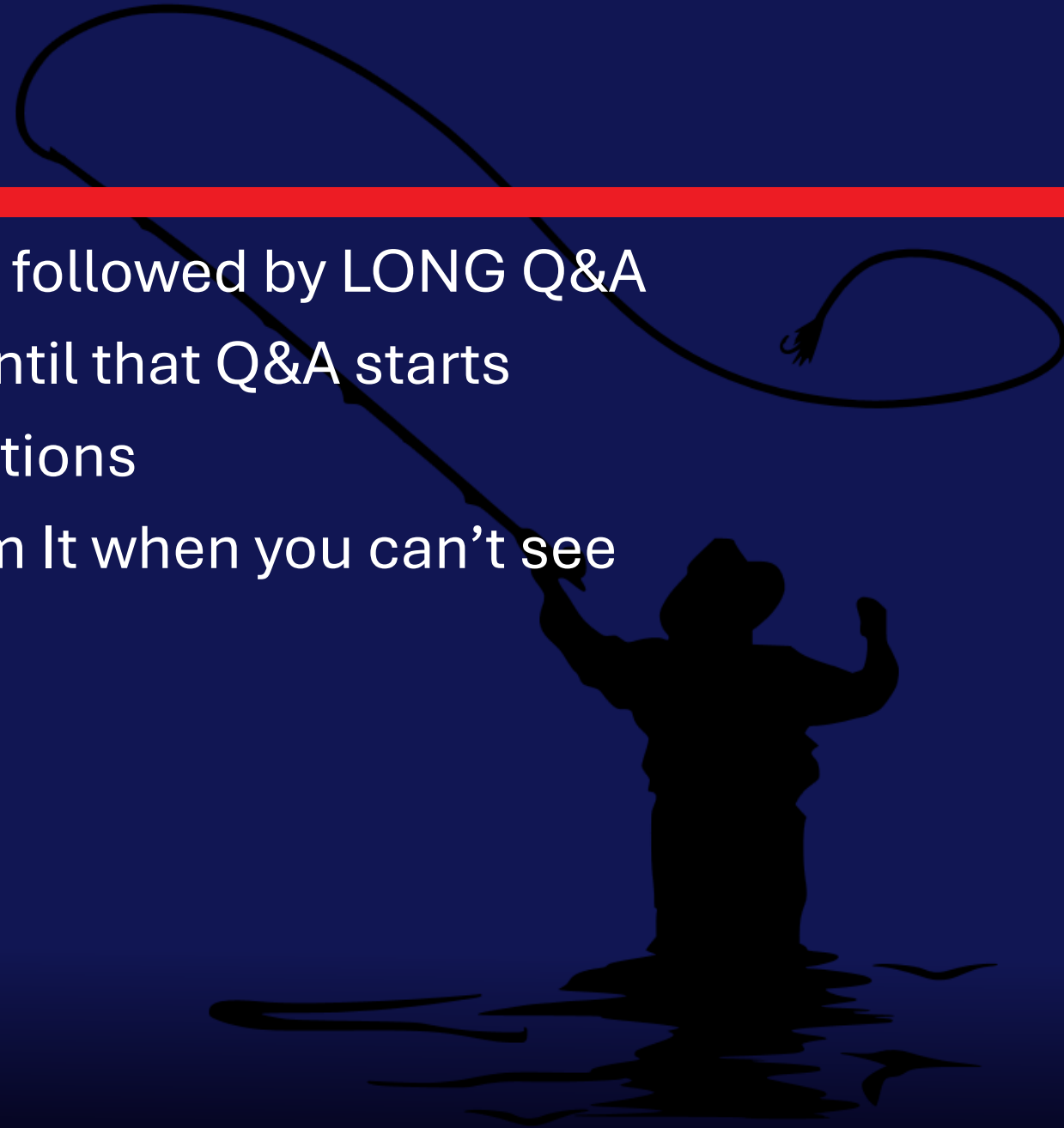
Onboard, Maintain, Destroy

The Secure Application Lifecycle



Attention

- ◆ MMS sessions are 60-75 minutes followed by LONG Q&A
- ◆ Please hold detailed questions until that Q&A starts
- ◆ Feel free to ask clarification questions
- ◆ Remind the speakers to use Zoom It when you can't see



Speakers



Michael Escamilla

Customer Engineer, PMPC



fishingpreacher



in/Michael-a-escamilla



Jim O'Neil

Customer Engineer, PMPC



jim.oneil@patchmypc.com

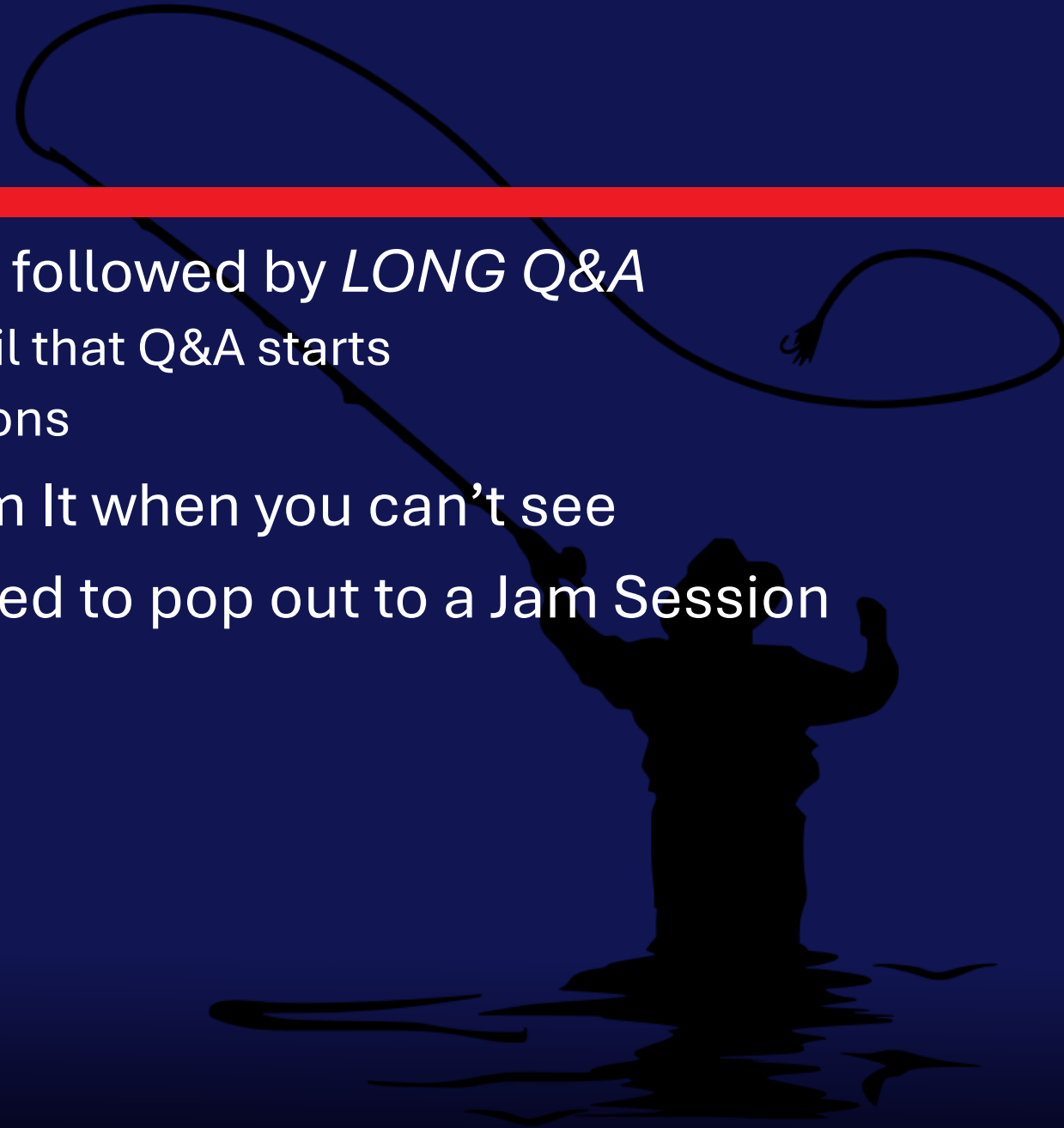


in/jimtheengineer

Can't see our slides? Can't hear? Need to repeat the question? Call us out!

Attention

- ♦ MMS sessions are 60-75 minutes followed by *LONG* Q&A
 - ♦ Please hold detailed questions until that Q&A starts
 - ♦ Feel free to ask clarification questions
- ♦ Remind the speakers to use Zoom It when you can't see
- ♦ Speakers are aware you might need to pop out to a Jam Session



Navigating Third-Party App Onboarding: Our Agenda

A silhouette of a person standing in a boat, holding a long pole with a lasso attached. The lasso is looped in the air, suggesting a throw. The background is a solid dark blue.

This presentation will guide us through a strategic framework for managing third-party applications from initial request to retirement. We will move beyond just the technical installation and focus on a collaborative, risk-aware approach.

Welcome – “Launch the Boat”

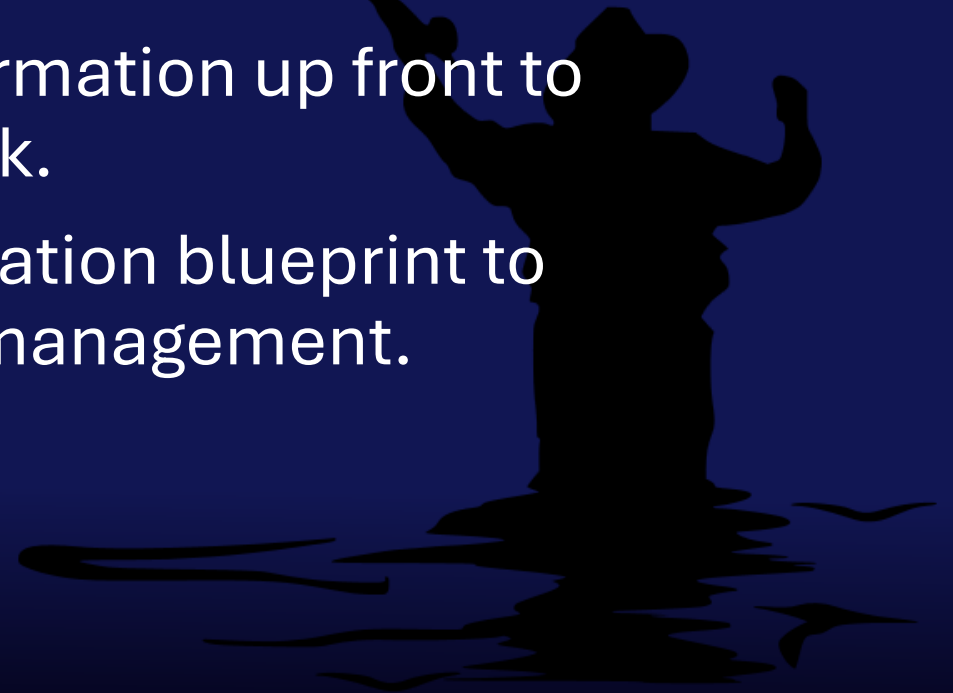
- ◆ Applications are the backbone of enterprise operations, yet onboarding third-party solutions introduces significant risks; security breaches, compliance failures, and operational inefficiencies.
- ◆ While other sessions this week cover installation, deployment, and updates, we’ll focus on a critical first step: establishing robust onboarding processes. Who approves applications for use in enterprise environments? Who ensures compliance with licensing terms and verifies code security for your endpoints?
- ◆ In this session, we won’t offer a one-size-fits-all solution but will empower you to build a tailored framework that strengthens security and compliance in your organization.

Key Discussion Points:

- ◆ **The Onboarding Challenge:** Why a streamlined process is critical for security and efficiency.
- ◆ **Our Four-Pillar Approval Framework:** A look at the key teams involved—**Architecture, Security, Procurement, and Legal**—and their roles in the decision-making process.
- ◆ **Technical Deep Dive:** Specific considerations for different software types, including the unique risks of **AI and LLMs**.
- ◆ **Beyond the Install:** What happens after a tool is approved, including **lifecycle management** and **continuous monitoring**.
- ◆ **Tools and Automation:** How we can use technology to make our process more efficient.

What you will get out of this...

- ◆ Know Your Gatekeepers: Identify key stakeholders and define your Four-Pillar Approval Framework.
- ◆ Think Beyond the Install: Plan the full application lifecycle — onboarding, usage, and end-of-life.
- ◆ Intake with Intent: Capture the right information up front to streamline approvals and reduce re-work.
- ◆ Automate the Mundane: Build an automation blueprint to accelerate intake, review, and lifecycle management.



Form Results



Survey Responses

Challenges

- ◆ No respondents indicated a fully formalized process
- ◆ Several responses indicate a lack of dedicated tracking tools, leading to confusion and inefficiency
- ◆ Lack of documentation or users not reading it.
- ◆ Manual processes and lack of tracking.
- ◆ Managing a high volume of requests with limited resources.
- ◆ Difficulty in identifying decision-makers.
- ◆ Rationalizing application ownership (e.g., “do we already own something?”).
- ◆ Formal decommissioning is a challenge for some.
- ◆ Most respondents never formally review or validate application approvals and risk assessments after initial deployment.

Could this be the root cause ?

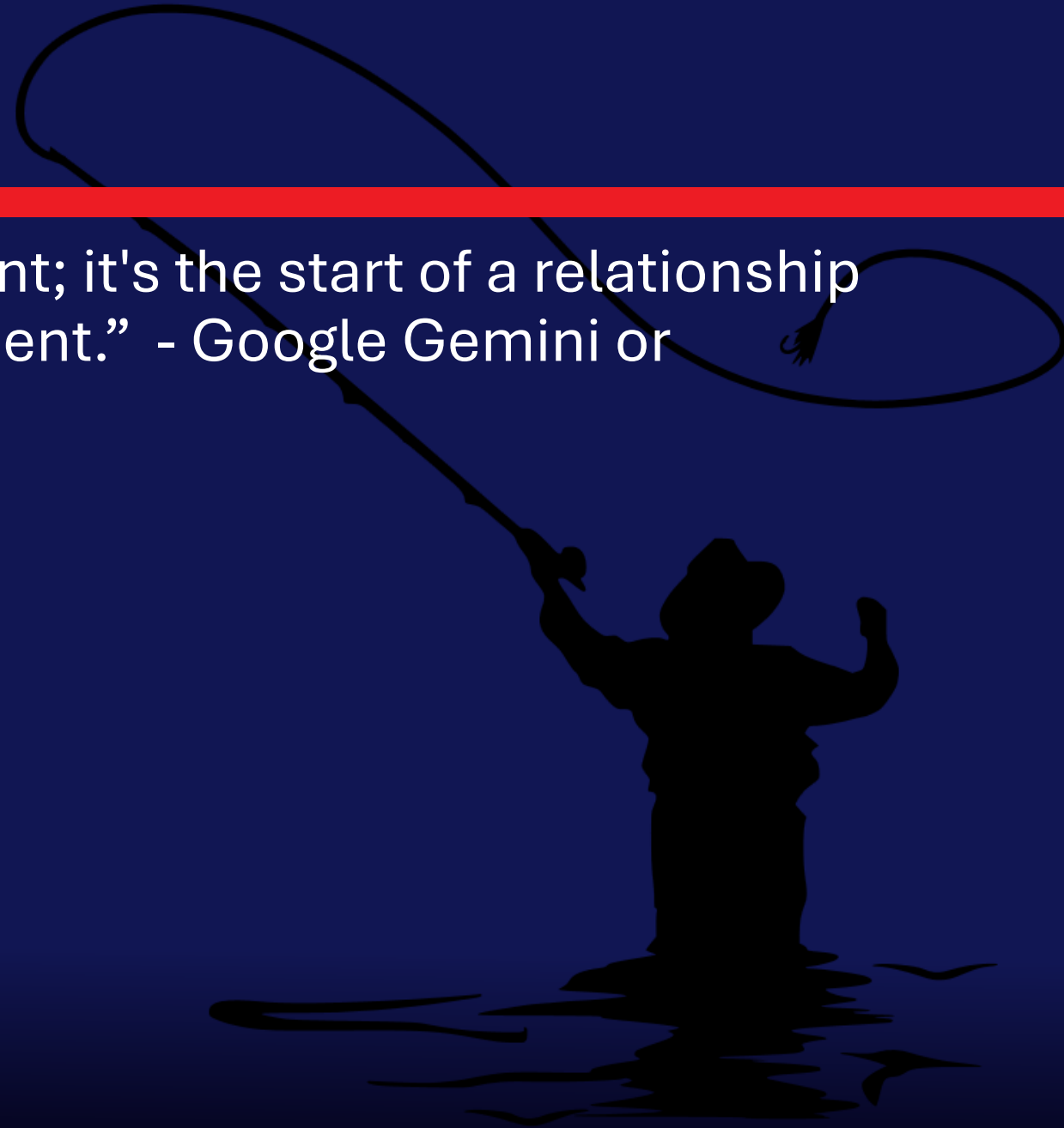
- ◆ The single biggest problem in communication is the illusion that it has taken place.
George Bernard Shaw
- ◆ Failing to plan is planning to fail. Benjamin Franklin
- ◆ In theory, there is no difference between theory and practice. In practice, there is.
Yogi Berra

What's YOUR Process?



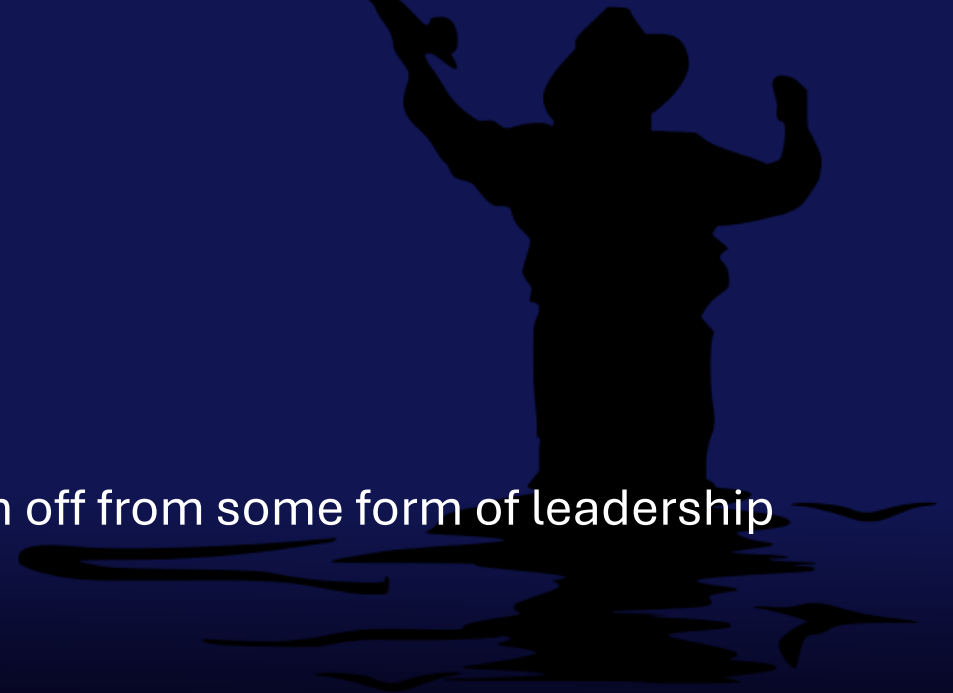
Onboarding

- ♦ “Onboarding isn't a one-time event; it's the start of a relationship that needs continuous management.” - Google Gemini or Someone Somewhere



Four Pillars of Approval

- ◆ Architecture
 - ◆ Use case – Duplicate software with same use
 - ◆ Compatibility
 - ◆ Is this something your IT team wants to support / Support Owner?
- ◆ Security
 - ◆ Vulnerability
 - ◆ Functionality / Data Privacy
 - ◆ Vendor Risk
- ◆ Legal & Procurement
 - ◆ License Types
 - ◆ AI / LLM Considerations
 - ◆ Who's paying for this
- ◆ Leadership
 - ◆ Depending on legal consideration you may want sign off from some form of leadership



RACI Model

A **RACI-based approach** is critical for processes like application lifecycle management because it brings **clarity, accountability, and speed** to a multi-team workflow.

- ♦ **R – Responsible**: The person(s) who actually do the work to complete the task.
- ♦ **A – Accountable**: The one ultimately answerable for the task's success. There should only be one A per task.
- ♦ **C – Consulted**: People who provide input or expertise before the work is done.
- ♦ **I – Informed**: People who need to be kept in the loop after decisions are made or work is completed.

Consequences...

Why RACI?

- ◆ Clear ownership
- ◆ Faster decisions
- ◆ Better compliance & auditability
- ◆ Improved collaboration

What happens if you don't use RACI?

- ◆ Role confusion
- ◆ Decision paralysis
- ◆ Compliance gaps
- ◆ Escalations & delays
- ◆ Blame culture



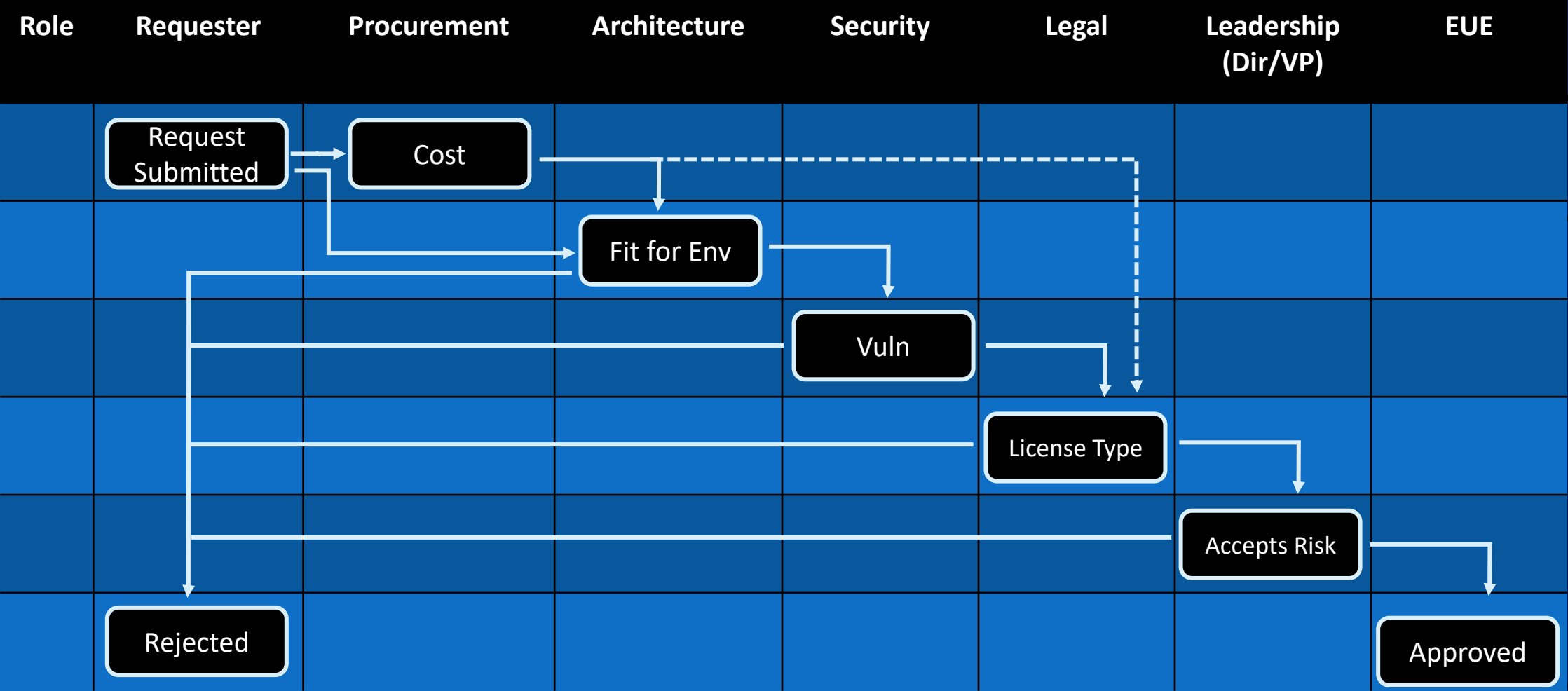
RACI for App Lifecycle Management

Task	Requester	Architecture	Security	Legal / Procurement	Product Owner	Leadership
Submit request & business case	R				A	
Duplicate & catalog check		R			A	
Data flow & classification		C	R		A	
Vendor due diligence			C	R	A	
License / contract review				R	A	
Risk acceptance (exceptions)			R		C	A or I
Publish to approved catalog		R	C	C	A	
Renewal / End-of-Life decision		C	C	R	A	I

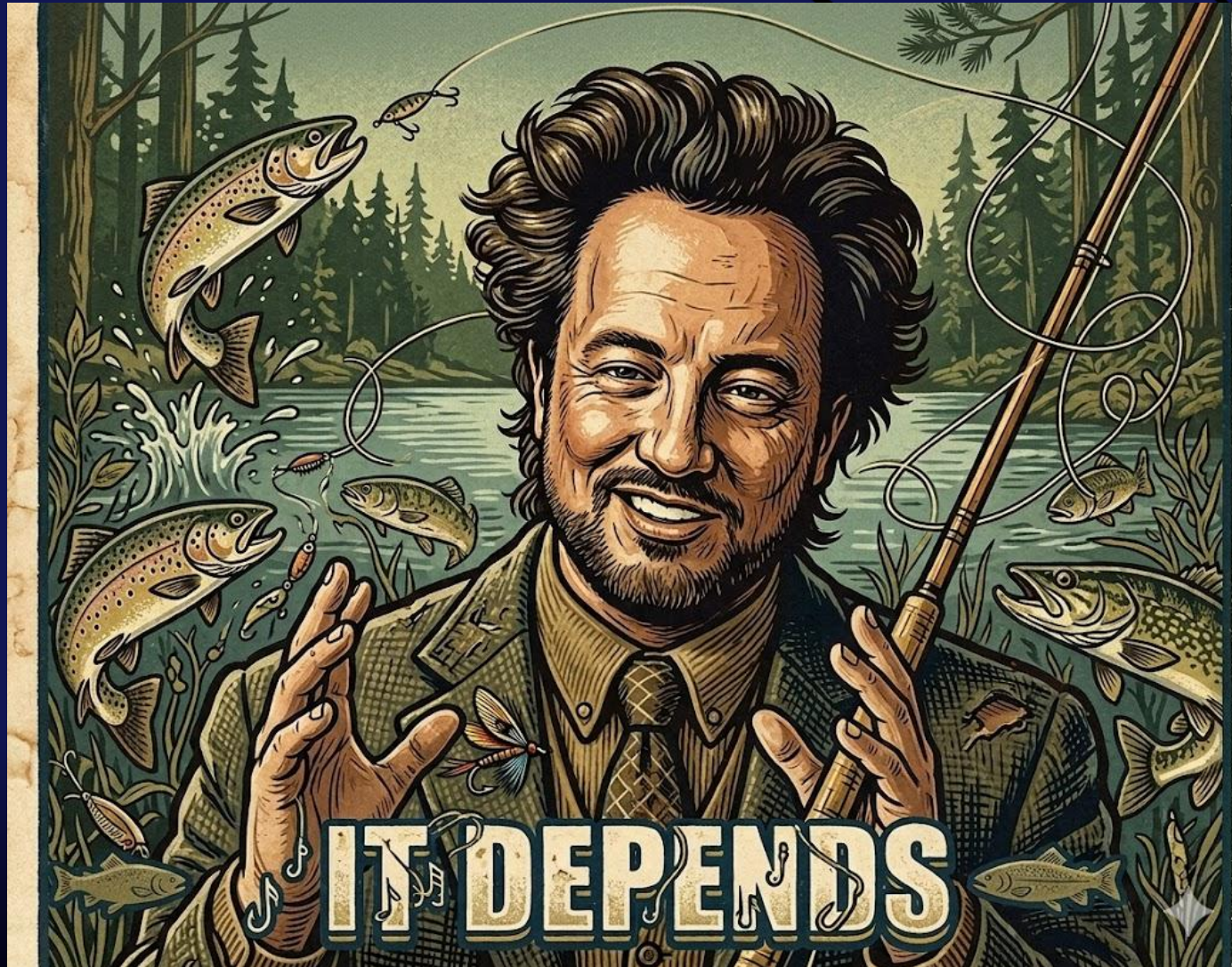
Application Request Diagram



Application Request Diagram



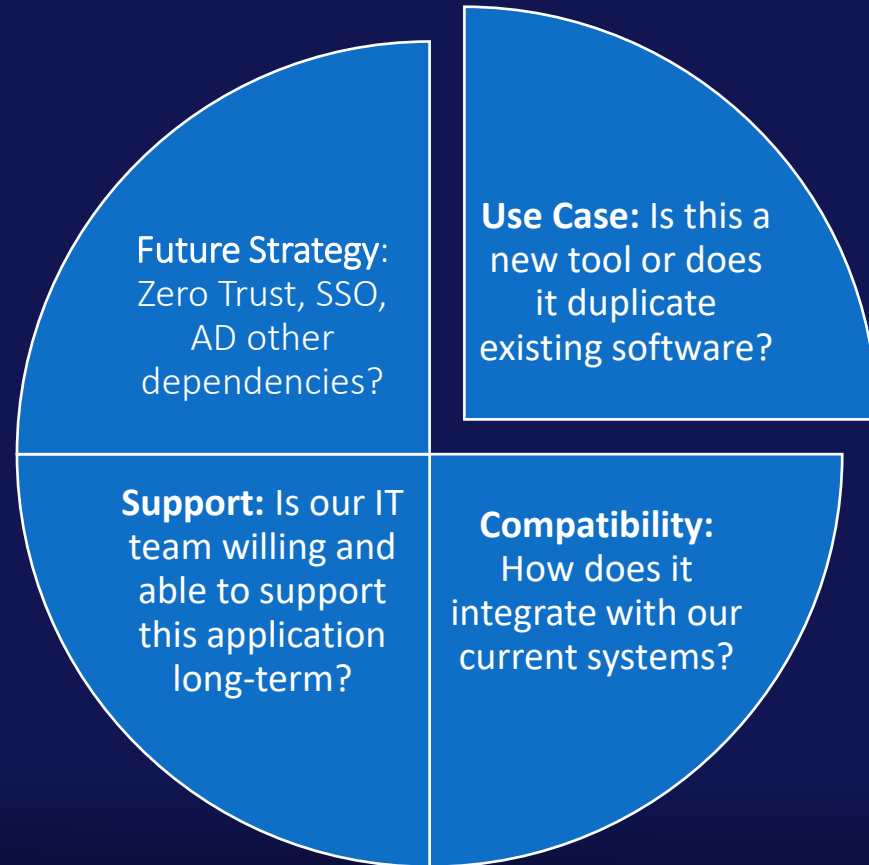
Approvals: Who Decides?



Who Decides?



Architecture: A Technical Gateway



Security: Protecting Our Data and Reputation

- ◆ **Vulnerability:** Does the software title have any current CVEs, frequency of CVEs?
- ◆ **Data Privacy:** How will our data be handled, stored, and protected?
- ◆ **Vendor Risk:** What is the vendor's track record?



Procurement & Legal

License Types

IP Ownership

Data
Ownership

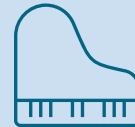
AI / LLM
Considerations



Leadership



Who ultimately accepts risk? (Mgr, Dir, VP)



Align with Legal on what license types need to get approved

Solutions for Managing Approval



Solutions for managing approval

◆ Tools

- ◆ ITSM
- ◆ SharePoint Form
- ◆ Power Platform
- ◆ Copilot Agent
- ◆ Internally Developed App

◆ Considerations

- ◆ Notification to stakeholders
- ◆ Easily accessible to all users
- ◆ Catalogs relevant information
- ◆ Serves as an “Approved” list of applications
- ◆ Shows status of approval and use

Ask a friend

- ◆ *I need to create a Copilot agent to assist with application life cycle management, can you come up with a plan for that? The purpose of the agent is to validate the app, look at compliance, vendor management, do we already have the app, administrative burden to manage the app etc.*

What's inside

```
twoday.AppGov.Solution.Starter.zip
├─ README/README.md
├─ SharePoint/Provisioning/app-intake-schema.xml      # PnP template (two lists)
├─ PowerAutomate/Flows/
│   ├── on_submit_triage.json                        # Trigger on new request
│   ├── search_approved_catalog.json                 # Duplicate detector
│   ├── search_intune_inventory.json                 # Defender XDR software scan
│   └── compute_score.json                           # Readiness score +
recommendation
│   ├── create_itsm_ticket_servicenow.json            # ITSM (ServiceNow)
│   ├── create_itsm_ticket_jira.json                  # ITSM (Jira)
│   ├── publish_decision_to_catalog.json              # Writes to Approved Apps
│   ├── notify_requester.json                         # Email/Teams update
│   └── schedule_renewal_reminder.json                 # Renewal reminder
├─ CopilotStudio/agent-manifest.json                  # Topics→Actions mapping
└─ Docs/DecisionMemoTemplate.docx                    # Auto-filled decision memo
```


Information Captured



Ownership

App Type

License Type

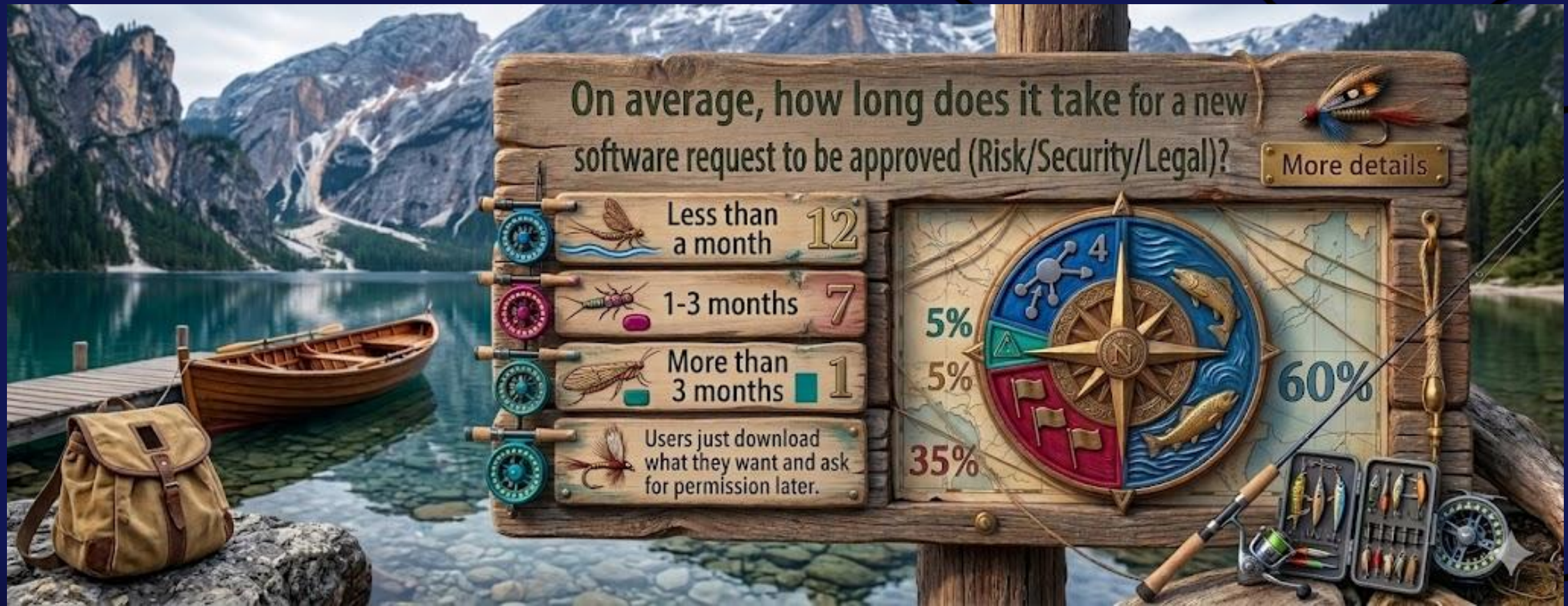
Contains AI

Business Case

Restrictions

Deployment Notes

Measuring Impact on Your Process



KPIs or Metrics

Our promise

- ◆ Time from request to approval to publishing
- ◆ Limit duplicate software or use case
- ◆ Security and compliance
- ◆ Hours spent managing software release process
- ◆ User sentiment

Management friendly examples

- ◆ Time from request → decision ↓50%
- ◆ % duplicate requests auto-diverted to existing tools ↑
- ◆ % decisions with complete legal & security evidence ↑
- ◆ Renewal lead time compliance(>30 days prior) ↑
- ◆ Average ops hours per approved app (baseline → target)

Maturity Roadmap

- ◆ **Weeks 0–2** — Discovery & data-mapping; confirm systems (Intune/ConfigMgr, ITSM, vendor risk source).
- ◆ **Weeks 3–6** — Build MVP: intake parsing, duplicate detector, legal excerpting, decision memo; wire read-only connectors.
- ◆ **Weeks 7–9** — Add actions to create/update ITSM tickets and publish decisions; add scorecard.
- ◆ **Weeks 10–12** — Expand to renewals/EOL reminders; add LLM risk checklist; pilot with 10 real requests; measure precision/recall of duplicate detection.
- ◆ **Post-pilot** — Harden, add role-based experiences (Requester, Reviewer, PO), and roll out to all new app requests.

Maturity Roadmap



Approving LLMs for Enterprise Use

- ◆ Licensing: Ensure open-source (e.g., Apache 2.0) or proprietary (e.g., Qwen license) aligns with commercial use; check restrictions (e.g., user limits).
- ◆ Data Privacy: Prioritize on-premises or secure cloud deployment; sanitize inputs/outputs.
- ◆ Procurement: Evaluate costs (infrastructure, APIs); confirm vendor reliability and SLAs.
- ◆ Ethics/Compliance: Mitigate bias; ensure regulatory alignment; enforce responsible AI policies.
- ◆ Integration: Confirm system compatibility; plan for updates and maintenance.

Approving LLMs for Enterprise Use

Core Qwen 2.5 Series (Base and Instruct Models)

These are the foundational text-based models.

Model Size	Type	Key Features	License
0.5B	Base / Instruct	Lightweight for edge devices; supports 128K context; strong in multilingual tasks.	Apache 2.0
1.5B	Base / Instruct	Efficient for mobile/consumer hardware; improved reasoning over Qwen 2.	Apache 2.0
3B	Base / Instruct	Balanced for research; good for fine-tuning on limited resources.	Qwen (non-commercial/research)

Approving LLMs for Enterprise Use

- ♦ **Apache 2.0:** Fully open-source and permissive. Allows commercial use, but requires including the license and copyright notices in distributions. No royalties or additional fees.
- ♦ **Qwen License:** More restrictive; intended for research/non-commercial use. **Commercial deployment may need explicit permission from Alibaba** (contact via their GitHub or official channels). For example, it prohibits use in services with over 100 million users without approval. This applies to the 3B and 72B models to protect larger, more capable variants. Always check the specific model's Hugging Face repository LICENSE file for the exact terms, as they can be updated.

Endpoint Protection – The Foundation of Control

If you don't block end users from installing unapproved apps... everything we just talked about goes out the window.



Endpoint Protection – The Foundation of Control

◆ Why It Matters:

- ◆ **Unapproved = Unvetted:** Apps bypassing the Four-Pillar Framework introduce unknown risks.
- ◆ **Lifecycle Chaos:** You can't monitor or manage what you didn't approve.
- ◆ **Security Breakdown:** Vulnerabilities, data leakage, and compliance violations become inevitable.
- ◆ **Efficiency Loss:** IT spends more time reacting than enabling.

◆ Our Safeguards:

- ◆ Enforced allowlists via endpoint management tools.
- ◆ Real-time telemetry and alerting on install attempts.
- ◆ Escalation workflows for legitimate exceptions.

“App governance starts at the endpoint — without it, the rest is just theory.”

Developer Workstations – Freedom with Fortification

Developers need flexibility to build and test — but that freedom must be secured.

- ◆ Policy Exceptions: Local admin rights, unapproved tools allowed
- ◆ Environment Isolation: Segmented from production and sensitive data
- ◆ Regular Audits: Access review Entra, usage, and compliance
- ◆ Clear Onboarding: Roles, responsibilities, and escalation paths

End of the Cycle...



Thank You!!



Extended Q&A



Recast



ninjaOne®

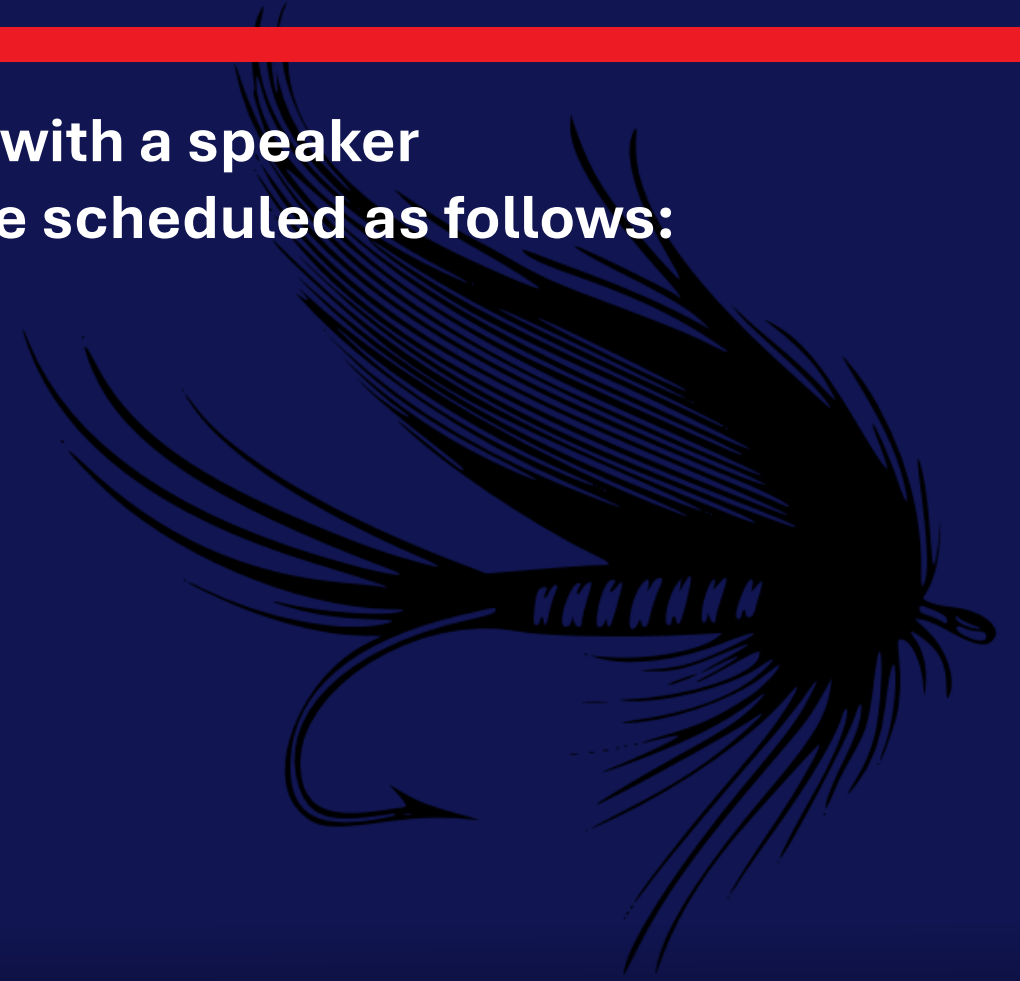


numecent®



Fishing Sessions

Be sure to find Wally and sign up for 1:1 time with a speaker
If you'd like to "catch" us for a session, we are scheduled as follows:



Don't forget to leave feedback for your speakers!

SAVE THE DATES

Oct 25-28, 2026



May 2-6, 2027



Oct 10-13, 2027



Extended Q&A



Recast



ninjaOne®



numecent®

